

# Case Study 2 - Design a Software Reference Architecture to Enhance Privacy and Security in Electronic Health Records

## AI-generated Architecture (generated by Copilot)

---

### 1. System summary

The system is an Electronic Health Record (EHR) platform whose purpose is “to propose a Software Reference Architecture (SRA) for Electronic Health Records (EHRs) with security and privacy considerations.” It manages, stores, and transmits patient data records for patients, healthcare professionals, managers, administrators, laboratories, government, insurers, and research entities, with strong emphasis on privacy and security.

Its primary objectives are to manage patient electronic records, support clinical workflows (notes, prescriptions, laboratory and imaging data), provide reporting and population health analysis, and enforce privacy, security, consent, audit, and compliance requirements (GDPR, HIPAA, ISO 18308:2011).

### 2. Assumptions

- **A-01:** The system is deployed in a networked environment where multiple user types access the EHR through client applications (e.g., web or desktop), since remote access and secure transmission are required (FR-002, FR-029).
- **A-02:** A logical central data repository exists for patient records, audit logs, and consent information, as implied by requirements to “store” and “integrate” data (FR-010–FR-013, FR-020, NFR-011).
- **A-03:** Interoperability (FR-019, NFR-008) implies interaction with external healthcare systems via standardized data exchange interfaces, but no specific standards are mandated beyond ISO 18308:2011.
- **A-04:** High availability and disaster recovery (FR-021, NFR-010) are achieved through redundant deployment of application and storage nodes, without assuming specific technologies.

### 3. Selected architecture style

**Selected style:** Layered, modular, service-based logical architecture.

**Justification:**

- **Separation of concerns:** Privacy, security, consent, audit, and clinical functions are distinct and benefit from modular components (e.g., Audit & Monitoring, Consent & Privacy Management, Clinical Documentation).
- **Support for quality attributes:** Layering (Presentation, Application/Domain Services, Data Management, Integration) supports security (controlled access paths), interoperability (integration layer), scalability (independent scaling of services), and reliability (clear data ownership).

- **Traceability and compliance:** Regulatory constraints (GDPR, HIPAA, ISO 18308:2011) are easier to enforce when security, audit, and consent are explicit cross-cutting services rather than embedded ad hoc in all components.

## 4. Architectural drivers

### 4.1 Functional drivers

Key functional requirements shaping the architecture:

- **Patient record management:** FR-001, FR-010–FR-016, FR-013 (manage records, store lab/imaging data, maintain history, integrate assessments).
- **Clinical workflows:** FR-003–FR-007 (clinical notes, prescriptions, drug interaction checks, clinical decision support).
- **User and access management:** FR-017–FR-018, FR-030–FR-033 (account details, authentication, access control, permissions).
- **Audit and monitoring:** FR-022–FR-026, FR-024–FR-025 (monitor access, track activities, maintain audit logs, identify security incidents).
- **Privacy and consent:** FR-027–FR-028, FR-036–FR-040 (protect PHI, anonymization, consent management, user control over access).
- **Interoperability and data lifecycle:** FR-019–FR-021 (interoperability, retention, archiving, backup, disaster recovery).
- **Emergency access:** FR-034–FR-035 (emergency access to critical information).
- **Reporting and analytics:** FR-008–FR-009 (reporting tools, population health trend analysis).

### 4.2 Quality attribute drivers

Architecturally significant non-functional requirements:

- **Privacy & Security:** NFR-001–NFR-004, NFR-013, NFR-015–NFR-016 emphasize confidentiality, integrity, availability, privacy preferences, and reduced re-identification risk. This drives explicit security, consent, anonymization, and audit components, plus secure communication paths.
- **Compliance & Ethics:** NFR-005–NFR-007, NFR-012 and constraints C-001–C-003 require alignment with GDPR, HIPAA, and ISO 18308:2011, motivating strong audit trails, data retention, and policy-driven access control.
- **Interoperability:** NFR-008 and FR-019 require a dedicated integration/interoperability component to manage data exchange with external systems.
- **Scalability & Availability:** NFR-009–NFR-010 push for modular services that can scale independently and a deployment view that supports continuity in adverse scenarios.
- **Reliability & Data loss protection:** NFR-011, FR-021, FR-027–FR-028 drive backup, disaster recovery, and robust data integrity mechanisms.
- **Accountability & Transparency:** NFR-014 requires detailed audit logging and reporting of system usage.

These drivers lead to a modular, layered architecture with explicit cross-cutting services for security, consent, audit, and data lifecycle management.

## 5. Requirements-to-architecture traceability

| Requirement ID       | Requirement                                                        | Architectural Component(s)                                                                               | Justification                                                        |
|----------------------|--------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------|
| <b>FR-001</b>        | Manage patient electronic records                                  | Patient Record Management Service                                                                        | Core responsibility to create, update, and retrieve patient records. |
| <b>FR-002</b>        | Provide healthcare professionals access to patient medical records | Presentation Layer (Professional UI), Access Control & Authentication, Patient Record Management Service | UI plus secure access control to records.                            |
| <b>FR-003</b>        | Insert clinical notes                                              | Clinical Documentation Service, Patient Record Management Service                                        | Clinical notes are part of patient records.                          |
| <b>FR-004–FR-006</b> | Prescribing, manage prescriptions, check interactions/allergies    | Prescription & Medication Management Service, Clinical Decision Support Service                          | Dedicated services for prescriptions and decision support.           |
| <b>FR-007</b>        | Clinical decision support tools                                    | Clinical Decision Support Service                                                                        | Provides CDS functions using patient data.                           |
| <b>FR-008–FR-009</b> | Reporting tools, population health trends                          | Reporting & Analytics Service                                                                            | Aggregates data and produces reports.                                |
| <b>FR-010–FR-013</b> | Store lab, radiology, imaging, integrate assessments               | Laboratory & Imaging Data Service, Patient Record Management Service                                     | Specialized storage integrated into patient records.                 |
| <b>FR-014–FR-016</b> | Manage profiles, demographics, history                             | Patient Profile & Demographics Service, Patient Record Management Service                                | Separate profile management linked to records.                       |

|                                                  |                                                                                              |                                                                                            |                                                                |
|--------------------------------------------------|----------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|----------------------------------------------------------------|
| <b>FR-017–FR-018</b>                             | Access account details, user account information                                             | User & Account Management Service                                                          | Manages user accounts and details.                             |
| <b>FR-019</b>                                    | Support interoperability                                                                     | Interoperability & External Systems Gateway                                                | Handles data exchange with other EHR systems.                  |
| <b>FR-020–FR-021</b>                             | Data retention, archiving, backup, disaster recovery                                         | Data Lifecycle & Archiving Service                                                         | Manages retention, archiving, backup, and recovery.            |
| <b>FR-022–FR-026</b>                             | Monitor access, track activities, audit logs, track data access, identify security incidents | Audit & Monitoring Service                                                                 | Centralized logging and incident detection.                    |
| <b>FR-027–FR-028</b>                             | Protect and safeguard PHI                                                                    | Security & Access Control Service, Data Integrity & Protection Mechanisms                  | Enforces confidentiality and integrity.                        |
| <b>FR-029</b>                                    | Encrypt data during transmission                                                             | Secure Communication Layer                                                                 | Ensures secure transmission between systems.                   |
| <b>FR-030–FR-033</b>                             | Authentication, terminate inactive sessions, regulate permissions, authorized access         | Security & Access Control Service, Session Management                                      | Implements authentication, authorization, and session control. |
| <b>FR-034–FR-035</b>                             | Emergency access and retrieval                                                               | Emergency Access Service                                                                   | Provides controlled emergency access paths.                    |
| <b>FR-036</b>                                    | Anonymization of personal data                                                               | Anonymization Service                                                                      | Performs anonymization for data use.                           |
| <b>FR-037–FR-040</b>                             | Consent and user-managed access                                                              | Consent & Privacy Management Service                                                       | Manages consent and user authorization preferences.            |
| <b>NFR-001–NFR-004, NFR-013, NFR-015–NFR-016</b> | Privacy and security                                                                         | Security & Access Control, Consent & Privacy Management, Anonymization, Audit & Monitoring | These components directly address privacy and security.        |
| <b>NFR-005–NFR-007, NFR-012, C-001–C-003</b>     | Ethics and compliance                                                                        | Compliance & Policy Management Service, Audit & Monitoring, Data Lifecycle & Archiving     | Enforces regulatory and ethical requirements.                  |
| <b>NFR-008</b>                                   | Interoperability                                                                             | Interoperability & External Systems Gateway                                                | Ensures seamless data exchange.                                |

|                        |                                        |                                                                     |                                                          |
|------------------------|----------------------------------------|---------------------------------------------------------------------|----------------------------------------------------------|
| <b>NFR-009–NFR-011</b> | Scalability, availability, reliability | Modular Services, Data Lifecycle & Archiving, Deployment Redundancy | Architectural structure supports scaling and continuity. |
| <b>NFR-014</b>         | Accountability                         | Audit & Monitoring, Reporting & Analytics                           | Provides transparency in EHR usage.                      |

## 6. Logical architectural components

### 6.1 Patient Record Management Service

- **Primary Responsibility:** Manage patient electronic records, including medical history and integrated clinical data.
- **Inputs:** Requests from Presentation Layer; clinical data from Clinical Documentation, Laboratory & Imaging, Prescription services.
- **Outputs:** Patient record views and updates; data to Reporting & Analytics and Interoperability Gateway.
- **Public Interfaces:** `getPatientRecord(patientId)`, `updatePatientRecord(patientId, recordData)`, `linkClinicalData(patientId, dataId)`.
- **Dependencies:** Patient Profile & Demographics Service, Laboratory & Imaging Data Service, Data Lifecycle & Archiving Service, Security & Access Control Service.

### 6.2 Clinical Documentation Service

- **Primary Responsibility:** Handle clinical notes and assessment data.
- **Inputs:** Clinician requests to create or update notes; assessment results.
- **Outputs:** Structured clinical documentation linked to patient records.
- **Public Interfaces:** `createClinicalNote(patientId, noteData)`, `getClinicalNotes(patientId)`.
- **Dependencies:** Patient Record Management Service, Security & Access Control Service.

### 6.3 Prescription & Medication Management Service

- **Primary Responsibility:** Manage prescriptions and medication-related data.
- **Inputs:** Prescribing requests from clinicians; patient medication history.
- **Outputs:** Prescription records; alerts for interactions/allergies.
- **Public Interfaces:** `createPrescription(patientId, prescriptionData)`, `getPrescriptions(patientId)`.
- **Dependencies:** Clinical Decision Support Service, Patient Record Management Service, Security & Access Control Service.

### 6.4 Clinical Decision Support Service

- **Primary Responsibility:** Provide decision support, including drug interaction and allergy checks.

- **Inputs:** Patient data, medication data, clinical rules.
- **Outputs:** Alerts, recommendations, decision support results.
- **Public Interfaces:** `checkDrugInteractions(patientId, medicationList)`, `generateCDSRecommendations(patientId)`.
- **Dependencies:** Patient Record Management Service, Prescription & Medication Management Service.

## 6.5 Laboratory & Imaging Data Service

- **Primary Responsibility:** Store and manage laboratory results, radiology reports, and imaging data.
- **Inputs:** Laboratory and imaging data from external systems or manual entry.
- **Outputs:** Structured lab and imaging records linked to patient records.
- **Public Interfaces:** `storeLabResult(patientId, labData)`, `storeImagingResult(patientId, imagingData)`, `getLabResults(patientId)`.
- **Dependencies:** Interoperability & External Systems Gateway, Patient Record Management Service.

## 6.6 Patient Profile & Demographics Service

- **Primary Responsibility:** Manage patient profiles, demographics, and identifiers.
- **Inputs:** Registration and update requests.
- **Outputs:** Profile data for other services.
- **Public Interfaces:** `createProfile(profileData)`, `updateProfile(patientId, profileData)`, `getProfile(patientId)`.
- **Dependencies:** Patient Record Management Service.

## 6.7 User & Account Management Service

- **Primary Responsibility:** Manage user accounts and account details.
- **Inputs:** User registration, updates, and queries.
- **Outputs:** User account information for authentication and authorization.
- **Public Interfaces:** `createUserAccount(userData)`, `getUserAccount(userId)`, `updateUserAccount(userId, userData)`.
- **Dependencies:** Security & Access Control Service.

## 6.8 Security & Access Control Service

- **Primary Responsibility:** Authentication, authorization, session management, and enforcement of access control policies.
- **Inputs:** Login requests, access requests, session activity.
- **Outputs:** Authentication tokens, authorization decisions, session termination.
- **Public Interfaces:** `authenticate(credentials)`, `authorize(userId, resource, action)`, `terminateInactiveSessions()`.
- **Dependencies:** User & Account Management Service, Consent & Privacy Management Service, Audit & Monitoring Service.

## 6.9 Session Management

- **Primary Responsibility:** Manage user sessions and automatic logoff.
- **Inputs:** User activity events.
- **Outputs:** Session state changes, session termination events.
- **Public Interfaces:** `startSession(userId)`, `updateSessionActivity(sessionId)`, `terminateSession(sessionId)`.
- **Dependencies:** Security & Access Control Service.

## 6.10 Consent & Privacy Management Service

- **Primary Responsibility:** Manage patient consent for data collection, use, disclosure, and user-controlled access.
- **Inputs:** Consent forms, patient preferences, access requests.
- **Outputs:** Consent records, authorization decisions based on consent.
- **Public Interfaces:** `recordConsent(patientId, consentData)`, `getConsent(patientId)`, `evaluateAccessWithConsent(patientId, requesterId, dataScope)`.
- **Dependencies:** Security & Access Control Service, Patient Record Management Service, Anonymization Service.

## 6.11 Anonymization Service

- **Primary Responsibility:** Support anonymization of personal data and reduce re-identification risk.
- **Inputs:** Patient data sets for secondary use.
- **Outputs:** Anonymized or pseudonymized data sets.
- **Public Interfaces:** `anonymizeData(dataSet, policy)`.
- **Dependencies:** Consent & Privacy Management Service, Patient Record Management Service.

## 6.12 Emergency Access Service

- **Primary Responsibility:** Provide controlled emergency access to critical patient information.
- **Inputs:** Emergency access requests, emergency flags.
- **Outputs:** Temporary access grants, audit events.
- **Public Interfaces:** `requestEmergencyAccess(userId, patientId, reason)`.
- **Dependencies:** Security & Access Control Service, Patient Record Management Service, Audit & Monitoring Service.

## 6.13 Audit & Monitoring Service

- **Primary Responsibility:** Monitor and record access, track user activities, maintain audit logs, and identify security incidents.
- **Inputs:** Events from all services (access, changes, errors).
- **Outputs:** Audit logs, incident alerts, usage reports.
- **Public Interfaces:** `logEvent(eventData)`, `getAuditLog(filter)`, `detectIncidents()`.
- **Dependencies:** All other services (as event sources), Reporting & Analytics Service.

## 6.14 Reporting & Analytics Service

- **Primary Responsibility:** Provide reporting tools and analyze data for population health trends and accountability.
- **Inputs:** Aggregated data from Patient Record Management, Laboratory & Imaging, Audit & Monitoring.
- **Outputs:** Reports, dashboards, analytics results.
- **Public Interfaces:** `generateReport(reportSpec)`, `analyzePopulationHealth(criteria)`.
- **Dependencies:** Patient Record Management Service, Laboratory & Imaging Data Service, Audit & Monitoring Service.

## 6.15 Interoperability & External Systems Gateway

- **Primary Responsibility:** Support interoperability and seamless data exchange with other EHR systems and external healthcare entities.
- **Inputs:** External data exchange requests, incoming data from external systems.
- **Outputs:** Transformed and validated data to internal services; outbound messages.
- **Public Interfaces:** `importExternalRecord(externalData)`, `exportRecord(patientId, targetSystem)`.
- **Dependencies:** Patient Record Management Service, Laboratory & Imaging Data Service, Security & Access Control Service.

## 6.16 Data Lifecycle & Archiving Service

- **Primary Responsibility:** Manage data retention, archiving, backup, and disaster recovery.
- **Inputs:** Data lifecycle policies, backup schedules, archive requests.
- **Outputs:** Archived data, restored data, backup sets.
- **Public Interfaces:** `archiveRecord(recordId)`, `backupData()`, `restoreData(backupId)`.
- **Dependencies:** Data Storage Layer, Compliance & Policy Management Service.

## 6.17 Compliance & Policy Management Service

- **Primary Responsibility:** Maintain policies for GDPR, HIPAA, ISO 18308:2011 compliance and ethical standards.
- **Inputs:** Regulatory requirements, organizational policies.
- **Outputs:** Policy rules for access, retention, consent, and audit.
- **Public Interfaces:** `getPolicy(policyId)`, `evaluatePolicy(policyId, context)`.
- **Dependencies:** Security & Access Control Service, Consent & Privacy Management Service, Data Lifecycle & Archiving Service, Audit & Monitoring Service.

## 6.18 Secure Communication Layer

- **Primary Responsibility:** Ensure encryption of data during transmission between systems.
- **Inputs:** Outgoing and incoming messages.
- **Outputs:** Encrypted/decrypted messages.



- **Public Interfaces:** `sendSecureMessage(message, destination), receiveSecureMessage(message).`
- **Dependencies:** Interoperability & External Systems Gateway, Presentation Layer.

## 6.19 Presentation Layer (Client Applications)

- **Primary Responsibility:** Provide user interfaces for patients, healthcare professionals, managers, administrators, laboratories, government, insurers, and researchers.
- **Inputs:** User interactions.
- **Outputs:** Requests to application services; rendered data.
- **Public Interfaces:** UI endpoints (e.g., `viewPatientRecord, enterClinicalNote, manageConsent`).
- **Dependencies:** Security & Access Control Service, all relevant domain services.

## 7. Component interactions

- **Control flow:**
  1. Users authenticate via Presentation Layer, which delegates to Security & Access Control Service and User & Account Management Service.
  2. Once authenticated, access requests (e.g., viewing a patient record) are sent to Patient Record Management Service, which consults Security & Access Control and Consent & Privacy Management to authorize the request.
  3. Clinical actions (notes, prescriptions, lab data) flow from Presentation Layer to respective services (Clinical Documentation, Prescription & Medication Management, Laboratory & Imaging Data), which update Patient Record Management.
  4. Audit & Monitoring Service receives events from all services and logs them, potentially triggering incident detection.
  5. Reporting & Analytics Service periodically aggregates data from Patient Record Management, Laboratory & Imaging, and Audit & Monitoring for reports and population health analysis.
  6. Interoperability & External Systems Gateway manages inbound/outbound data exchange, using Secure Communication Layer for encrypted transmission.
- **Data flow:**
  1. Patient data originates in Patient Profile & Demographics and Patient Record Management, enriched by Clinical Documentation, Laboratory & Imaging, and Prescription services.
  2. Consent & Privacy Management stores consent data and is consulted before data is shared or accessed.
  3. Anonymization Service transforms data sets for secondary use, feeding Reporting & Analytics or external systems via Interoperability Gateway.
  4. Data Lifecycle & Archiving Service moves data between active storage and archives, and manages backups and restores.
- **Communication:**
  1. Services communicate via well-defined interfaces within the application layer.
  2. Presentation Layer communicates with application services through secure endpoints.

3. External systems communicate through Interoperability & External Systems Gateway, using Secure Communication Layer for encrypted transmission.

## 8. Data management strategy

- **Data ownership:**
  - Patient Record Management Service owns core clinical records.
  - Patient Profile & Demographics owns demographic and identity data.
  - Laboratory & Imaging Data Service owns lab and imaging data.
  - Consent & Privacy Management owns consent records and privacy preferences.
  - Audit & Monitoring owns audit logs and incident records.
  - Data Lifecycle & Archiving owns archived and backup data.
- **Persistence strategy:**
  - Each logical data domain (patient records, profiles, lab/imaging, consent, audit, archives) is persisted in logically separate data stores or schemas to support privacy, security, and retention policies.
  - Audit logs are append-only to preserve accountability and integrity.
  - Archived data is stored in long-term storage managed by Data Lifecycle & Archiving Service.
- **Data flow:**
  - Data flows from input services (Clinical Documentation, Laboratory & Imaging, Prescription) into Patient Record Management.
  - Consent data is consulted before data is accessed or shared.
  - Anonymization Service produces derived data sets for analytics and external sharing.
  - Backup and restore operations move data between active stores and backup repositories.
- **Storage responsibilities:**
  - Data Storage Layer (logical) provides persistence for all services, with Data Lifecycle & Archiving enforcing retention and archiving policies aligned with compliance requirements.

## 9. External system interactions

Explicitly supported external interactions:

- **Other EHR systems:** Via Interoperability & External Systems Gateway (FR-019, NFR-008, “Other EHR systems” in intended users).
- **Laboratory systems:** For lab data ingestion and reporting (FR-010, “Laboratory” as intended user).
- **Radiology/imaging systems:** For diagnostic imaging results (FR-011–FR-012).
- **Insurance companies:** For data exchange related to patient records (intended users).
- **Government and research companies:** For reporting and anonymized data sharing (FR-009, NFR-016, intended users).

All external interactions use the Secure Communication Layer to ensure encrypted transmission (FR-029, NFR-013).

## 10. Architectural quality considerations

- **Modularity:**
  - Distinct services for records, clinical documentation, prescriptions, lab/imaging, consent, anonymization, audit, interoperability, and data lifecycle support maintainability and clear responsibilities.
- **Security & Privacy:**
  - Security & Access Control, Consent & Privacy Management, Anonymization, Secure Communication, and Audit & Monitoring collectively enforce confidentiality, integrity, availability, consent, and privacy preferences (NFR-001–NFR-004, NFR-013, NFR-015–NFR-016, FR-027–FR-033, FR-036–FR-040).
- **Compliance & Ethics:**
  - Compliance & Policy Management, Data Lifecycle & Archiving, and Audit & Monitoring ensure alignment with GDPR, HIPAA, ISO 18308:2011, and ethical standards (NFR-005–NFR-007, NFR-012, C-001–C-003).
- **Interoperability:**
  - Interoperability & External Systems Gateway and Secure Communication Layer support seamless data exchange (NFR-008, FR-019).
- **Scalability & Availability:**
  - Modular services can be scaled independently; deployment assumptions include redundant application and storage nodes to support service continuity (NFR-009–NFR-010).
- **Reliability & Data loss protection:**
  - Data Lifecycle & Archiving, backup and disaster recovery, and robust data integrity mechanisms address NFR-011, FR-021, FR-027–FR-028.
- **Accountability & Transparency:**
  - Audit & Monitoring and Reporting & Analytics provide detailed logs and reports (NFR-014, FR-022–FR-026, FR-008–FR-009).

## 11. Architectural decisions and trade-offs

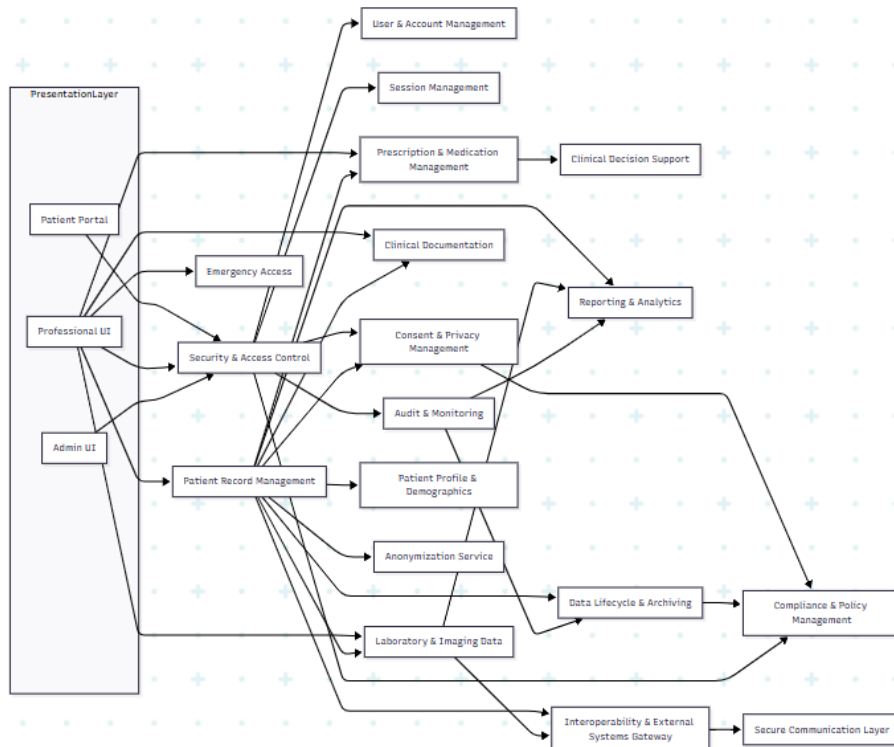
| Decision                                                                            | Rationale                                              | Advantages                                                                    | Potential Disadvantages                      |
|-------------------------------------------------------------------------------------|--------------------------------------------------------|-------------------------------------------------------------------------------|----------------------------------------------|
| <b>Use layered, modular, service-based architecture</b>                             | Supports separation of concerns and quality attributes | Clear responsibilities, easier maintenance, scalability, security enforcement | Increased complexity in service coordination |
| <b>Separate Consent &amp; Privacy Management from Security &amp; Access Control</b> | Consent is distinct from authentication/authorization  | Better alignment with privacy requirements and user-managed access            | More components to integrate and configure   |
| <b>Dedicated Audit &amp; Monitoring Service</b>                                     | Centralizes logging and incident detection             | Strong accountability,                                                        | Requires careful design to avoid             |

|                                                            |                                                               |                                                              |                                                     |
|------------------------------------------------------------|---------------------------------------------------------------|--------------------------------------------------------------|-----------------------------------------------------|
|                                                            |                                                               | easier compliance reporting                                  | performance overhead                                |
| <b>Introduce Anonymization Service</b>                     | Explicitly addresses anonymization and re-identification risk | Supports research and secondary use while protecting privacy | Additional processing overhead and complexity       |
| <b>Use Interoperability &amp; External Systems Gateway</b> | Encapsulates external interactions                            | Easier integration, consistent security and data mapping     | Requires ongoing adaptation to external standards   |
| <b>Logical separation of data domains</b>                  | Aligns with privacy, retention, and integrity requirements    | Better control over access and lifecycle policies            | Potential overhead in managing multiple data stores |

## 12. Architectural risks and limitations

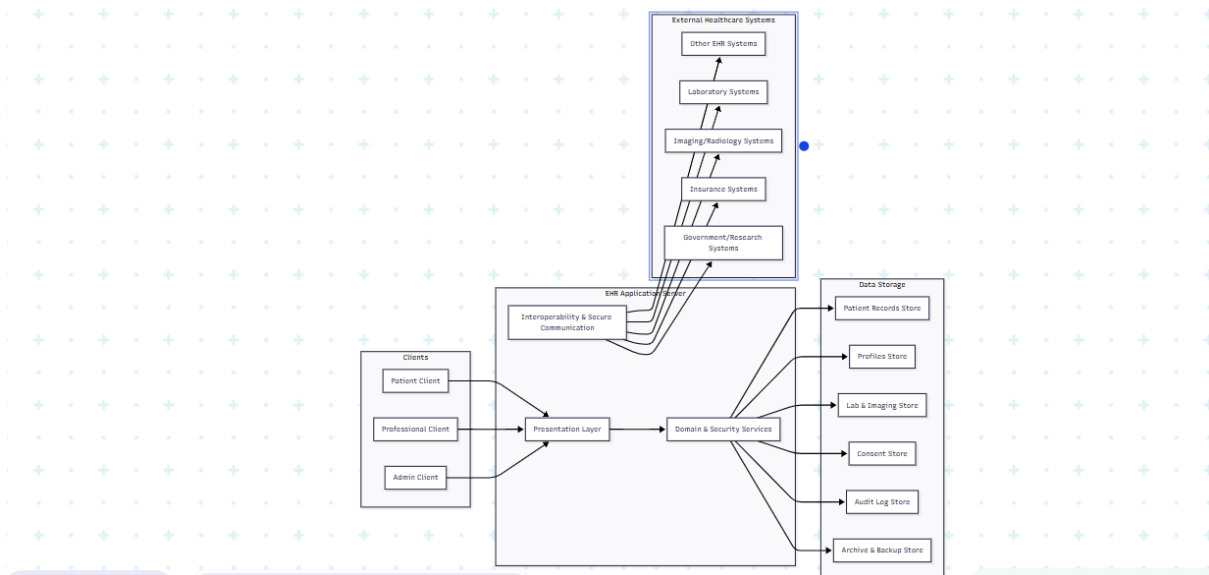
- **Risk:** Misconfiguration of consent and access policies could lead to unauthorized access or over-restriction of data.
- **Risk:** Performance overhead from extensive auditing, encryption, and anonymization may impact responsiveness.
- **Risk:** Interoperability challenges with diverse external systems and evolving standards.
- **Limitation:** The architecture is logical and does not specify concrete technologies; actual implementation choices may affect security, scalability, and reliability.
- **Limitation:** Detailed clinical decision support rules and algorithms are not specified in the SRS and must be defined separately.
- **Future refinement:** More detailed data models, policy rule definitions, and incident response workflows should be elaborated to fully meet compliance and security requirements.

## 13. Mermaid component diagram



## 14. Mermaid deployment diagram

**Assumption:** A logical deployment environment with client devices, an application server tier, a data storage tier, and external systems.



## 15. Conclusion

This architecture is derived solely from the provided SRS and directly addresses the functional requirements (patient record management, clinical workflows, reporting, interoperability, consent, audit, emergency access) and non-functional requirements (privacy, security, compliance, interoperability, scalability, availability, reliability, accountability). By using a layered, modular, service-based structure with explicit components for security, consent, anonymization, audit, interoperability, and data lifecycle, the architecture provides clear traceability from requirements to components and offers a robust foundation for implementing an EHR system that enhances privacy and security in line with GDPR, HIPAA, and ISO 18308:2011.